

Final Project Report: Phishing and Ransomware Attack

By:

Ayub Haji, Joel Thomas, and John Patrick Capito

Introduction:

In an era defined by digital connectivity, cybersecurity threats have evolved from isolated incidents into sophisticated, large-scale operations capable of crippling organizations across every sector. Among the most pervasive and damaging of these threats are phishing attacks and ransomware, two closely linked vectors that have become the weapons of choice for cybercriminals worldwide due to their high success rates.

Phishing attacks exploit the most vulnerable element of any security system: human judgment. By impersonating trusted entities through deceptive emails, messages, or websites, attackers manipulate individuals into divulging sensitive credentials, clicking on malicious links, or unknowingly granting access to secure systems. These attacks serve as a primary springboard for a far more destructive threat, ransomware.

Ransomware is malicious software that encrypts a victim's data and holds it hostage until a ransom is paid, often in untraceable cryptocurrencies like Bitcoin. When successfully deployed, it can bring hospitals, government agencies, financial institutions, and private enterprises to a complete standstill, resulting in millions of dollars in losses, operational downtime, and lasting reputational damage.

This report will examine the phases of this sophisticated attack and the strategies organizations can adopt to defend against them.

Methodology:

Phase 1: Phishing Email

Here is a possible scenario in a university setting: **Encrypting the University's Research Database**

- Student A, a computer science researcher with advanced technical knowledge, embeds ransomware into a seemingly legitimate research paper shared with a faculty researcher. Once they open the document, it triggers the ransomware. It silently spreads across the university's research network, encrypting years of irreplaceable research data, grant proposals, and lab results. The university receives a ransom demand of hundreds of thousands of dollars and faces the additional threat of having sensitive federally funded research permanently destroyed.

Phase 2: Searching Important Files

In this phase, we are going to create a search algorithm that checks the location of important files on the victim filesystem.

Phase 3: Encrypting the Files and Creating Scary Banner

In this phase, we are going to encrypt the files and display a scary banner. Requesting for an amount of money be sent to bitcoin address in exchange for their data being returned to them.

Phase 4: Sending the Decryption Key

In this phase, the victim has sent the requested amount of money and gets the decryption key to get back their data.

System Design and Components:

The ransomware is designed using modular architecture to separate functionality into different components.

The main components include:

- `main.py`: Controls the execution flow of the ransomware
- `filediscovery.py`: Responsible for scanning and locating files
- `Encryption.py`: Handles file encryption
- `Decryption.py`: Handles the decryption of files
- `banner.py`: Displays the ransom message using a graphical interface
- `attacker_public_key.pem` and `attacker_private_key.pem`: Keys used for encryption and decryption.

The `main.py` script acts as the entry point. It first scans the system for files, then encrypts them, and finally launches the ransom message interface.

This modular design improves clarity and reflects how real malware is structured into multiple functional units

Impact of the Attack:

The ransomware can have significant impact on a system, including:

- Loss of access to important files
- Potential permanent data loss
- Financial pressure on the victim
- Disruption of normal system usage

Even in this simplified implementation, the attack demonstrates how quickly a system can become unusable when files are encrypted.

Prevention and Defensive Strategies:

Email Security and Anti-Phishing

- Deploy email filtering solutions that scan attachments and URLs for malicious content.
- Implement DMARC, DKIM, and SPF records to reduce email spoofing.
- Conduct regular phishing simulation exercises and security awareness training for all staff.
- Disable macro execution in Office documents by default via Group Policy.

Endpoint Protection

- Maintain up-to-date antivirus and endpoint detection and response (EDR) solutions.
- Apply operating system and application patches promptly — many ransomware strains exploit known, patched vulnerabilities.
- Apply the principle of least privilege — users should have only the access rights necessary for their role.
- Disable unused services and ports, particularly RDP on internet-facing systems.

Backup and Recovery

- Maintain regular, tested backups using the 3-2-1 rule: 3 copies, on 2 different media, with 1 stored offsite or offline.
- Ensure backups are not accessible from the primary network — ransomware frequently targets connected backup systems.
- Test backup restoration procedures regularly — a backup that has never been tested is not a reliable backup.

Network Segmentation and Monitoring

- Segment networks so that a compromised endpoint cannot directly reach critical servers or other workstations.

- Deploy Security Information and Event Management (SIEM) systems to detect anomalous file access patterns indicative of ransomware activity.
- Monitor for unusual volumes of file rename or encryption operations, which can trigger early detection.

Incident Response Planning

- Develop and regularly test a documented incident response plan that includes ransomware scenarios.
- Establish relationships with law enforcement (e.g., FBI, CISA) and cybersecurity incident response firms in advance.
- Know that paying the ransom is not recommended — it funds criminal activity, does not guarantee recovery, and may have legal implications.

Conclusion:

This project demonstrates how ransomware operates through a practical implementation. By simulating file discovery, encryption, and ransom display, we were able to observe how such attacks impact a system.

Understanding these mechanisms is essential for developing effective defenses. As ransomware continues to evolve, knowledge of attack techniques plays a critical role in cybersecurity.